SE-004 — Incident Reporting and Security Escalation

Document control

Field	Value
Document ID	SE-004
Title	Incident Reporting and Security Escalation
Version	4.2
Owner	Security Incident Commander
Approver	Chief Information Security Officer
Effective date	March 14, 2025
Review cycle	Semi-annual
Audience	All workforce members, Security Operations, Service Desk
Classification	Internal

Document type: Runbook — execute in the sequence below

1. Trigger conditions

Execute this runbook when any of the following occurs:

- Suspected unauthorized access to a system or data
- Suspected data loss or exfiltration
- Ransomware or destructive malware detected
- Loss or theft of a device containing Confidential or Restricted data
- Loss or theft of credentials
- Business email compromise
- Denial-of-service attack
- Physical security incident affecting information systems
- Suspected insider threat
- Third-party or supply chain incident affecting ABC CORP

2. Severity levels

Severity	Definition	Examples
SEV-1 Critical	Material impact to ABC CORP operations, data, or regulatory standing	Active data exfiltration; ransomware; compromise of production systems; compromise of executive accounts
SEV-2 High	Significant impact, contained or containable	Compromise of individual accounts; malware contained to endpoints; loss of a device with Confidential data
SEV-3 Medium	Limited impact, contained	Compromise of accounts without evidence of misuse; malware detected and blocked; lost device with Internal data
SEV-4 Low	Minimal impact	Suspicious activity investigated and cleared; policy violations without data impact

3. T+0 to T+30 minutes — Detection and initial response

T+0 — Report received.

Service Desk or Security Operations receives a report. Log in the incident management system. Assign an incident number and initial severity estimate.

T+5 — Acknowledge to reporter.

Acknowledge receipt. Do not speculate on cause, scope, or resolution. Provide the incident number.

T+10 — Initial assessment.

Determine:

- What was affected (system, data, user, physical location)
- When the incident started (as closely as can be determined)
- Whether the incident is ongoing
- Whether the reporter is the source or a witness

T+15 — Assign Incident Commander.

SEV-1 and SEV-2 assign an Incident Commander immediately. SEV-3 and SEV-4 are managed by the Security Operations shift lead.

T+20 — Contain or not contain.

The Incident Commander decides whether to contain or observe. Containment is the default for SEV-1 and SEV-2. Observation may be appropriate when containment would tip off an attacker before more is learned.

T+30 — Stakeholder notification.

Notify per Section 5.

4. Investigation phase

T+30 to T+2 hours — Establish facts.

The Incident Commander establishes:

- The attack vector (or best hypothesis)
- The scope (how many systems, users, or records affected)
- Whether the incident is still active
- Whether the attacker has persistence

T+2 hours — Initial incident report.

Written to the incident management system. Includes:

- Incident summary
- Current severity
- Affected systems and data
- Actions taken to date
- Immediate next steps

T+4 hours — Evidence preservation.

Preserve logs, system images, and any other evidence. Do not remediate until evidence is preserved unless remediation is required to stop ongoing harm.

Ongoing — Regular updates. The Incident Commander provides updates to stakeholders at intervals defined by severity (see Section 5).

5. Communication matrix

Severity	Notify	Initial notification	Update cadence
SEV-1	CISO, COO, CEO, Legal, Communications, affected business units	Within 30 minutes	Hourly
SEV-2	CISO, affected business unit leadership, Legal (if data involved)	Within 60 minutes	Every 2 hours
SEV-3	CISO, affected business unit	Within 4 hours	Daily
SEV-4	Security leadership	Within 1 business day	Weekly

Regulatory notification. Where the incident may trigger a regulatory notification obligation (GDPR, state breach laws, HIPAA, PCI DSS), the Incident Commander notifies Legal immediately. Legal determines whether and when to notify.

Client notification. Client-facing incidents are coordinated with the account team and Legal. Do not notify clients directly from Security Operations.

Internal communication. Company-wide communication about an incident is coordinated with Communications. Do not post about incidents in internal chat channels outside the incident bridge.

6. Containment actions

The Incident Commander may direct any of the following:

- Isolate endpoints from the network
- Disable user accounts
- Revoke sessions and tokens
- Block IP addresses and domains at the perimeter
- Disable services
- Rotate credentials for affected accounts and service accounts
- Physically secure affected facilities

Containment actions are logged with timestamp and authorizing role.

7. Eradication and recovery

Once containment is stable:

- Identify and remove the attacker's foothold
- Patch the vulnerability that allowed the incident
- Restore affected systems from clean backups
- Verify restoration before returning systems to production
- Reset credentials that may have been exposed
- Monitor for 30 days after recovery for signs of return

The Incident Commander approves the return to production. SEV-1 and SEV-2 require sign-off from the CISO.

8. Post-incident review

Within 10 business days of closing an incident of SEV-1 or SEV-2 severity, the Incident Commander conducts a post-incident review.

The review:

- Reconstructs the timeline
- Identifies root cause
- Identifies contributing factors
- Identifies what worked and what did not
- Produces action items with owners and due dates

The review is documented and reviewed by the CISO. Action items are tracked to completion.

SEV-3 and SEV-4 incidents receive a lighter review documented in the incident record.

9. Reporting to authorities

- Do not report to law enforcement without Legal's involvement. Legal coordinates law enforcement engagement.
- Do not notify regulators directly. Legal coordinates regulatory notification.
- Preserve evidence in a forensically sound manner if law enforcement involvement is anticipated.

10. Individual responsibilities

Every ABC CORP workforce member has the following responsibilities:

- Report suspected incidents immediately

- Do not attempt to investigate independently
- Do not discuss incidents outside the incident bridge
- Preserve evidence — do not delete or modify files, do not shut down machines when directed not to
- Cooperate with the investigation

Reporting an incident is never wrong. ABC CORP does not penalize good-faith reporting. Failure to report — not reporting an incident — is a policy violation.

11. Related documents

- SE-001 Information Classification and Handling Standard
- SE-002 Phishing, Malware, and Suspicious Email Response
- SE-005 Acceptable Use, Device, and Clean Desk Compliance
- IT-002 Password, MFA, and Credential Reset Procedure
- BC-001 Business Continuity and Disaster Recovery Helpdesk Playbook
- SD-002 Escalation, Handoff, and Major Incident Communication

12. Revision history

Version	Date	Change
3.0	05/20/2023	Restructured as timed runbook
4.0	03-14-2024	Communication matrix revised; post-incident review added
4.2	March 14, 2025	Regulatory notification language clarified; individual responsibilities expanded